



1b. Defence Overview

Garrison Gao

garrison.gao@uwa.edu.au

Introduction: outline

- ◇ What is security?
- ◇ Security objectives
- ◇ Defense overview
- ◇ Risk management
- ◇ Cyber something

Quick stop: Terminology

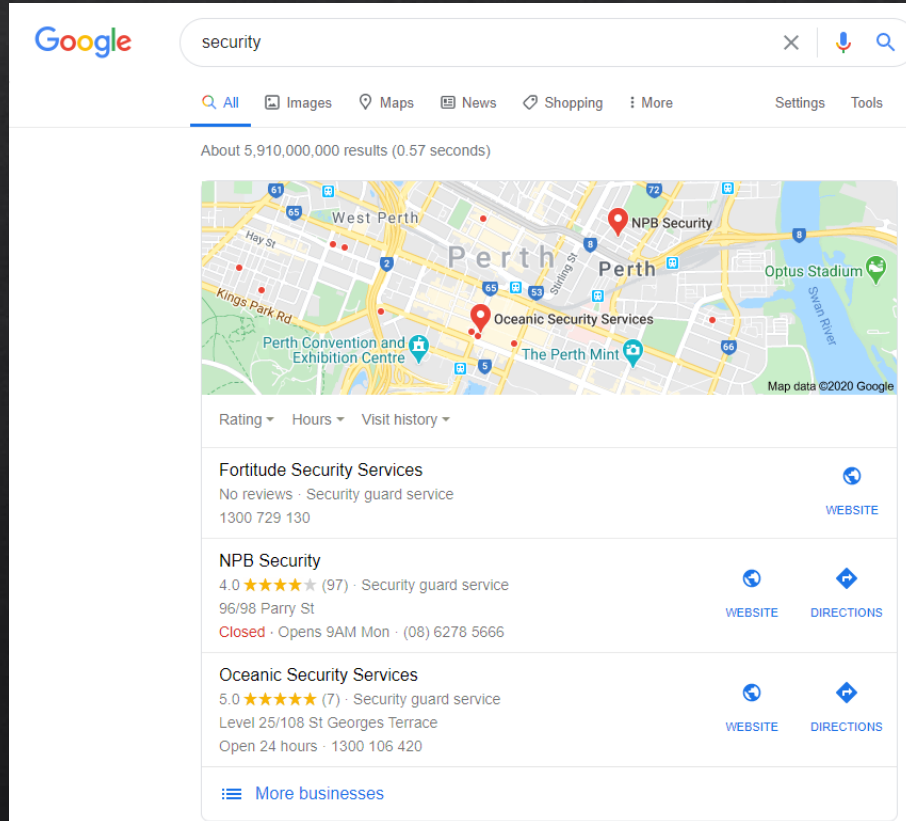
Term	Meaning
Risk	The potential for an unwanted or adverse outcome resulting from an incident, event, or occurrence, as determined by the likelihood (or the potential) that a particular threat will exploit a particular vulnerability , with the associated consequences.
Vulnerability	A characteristic or specific weakness that renders an organization or asset (such as information or information system) open to exploitation by a given threat or susceptible to a given hazard.
Exploitation	A technique to breach the security of a network or information system in violation of security policy.
Threat	A circumstance or event (including accidental and non-human related) that has or indicates the potential to exploit vulnerabilities and to adversely impact (create adverse consequences for) organizational operations, organizational assets (including information and information systems), individuals, other organizations, or society.
Asset	A person, structure, facility, information, and records, information technology systems and resources, materials, process, relationships, or reputation allowing entities (e.g., individuals, businesses and governments) to achieve social, economic, and other objectives of value .

Quick stop: Terminology

- ◇ **Asset**: A house and things inside
- ◇ **Vulnerability**: Unlocked door or broken lock, representing a weakness that can be exploited
- ◇ **Threat**: A burglar who notices the weak or unlocked door and intends to break in (have both the capability and intent to cause harm)
- ◇ **Risk**: The possibility that the burglar actually enters the house and steals valuables such as jewellery or electronics

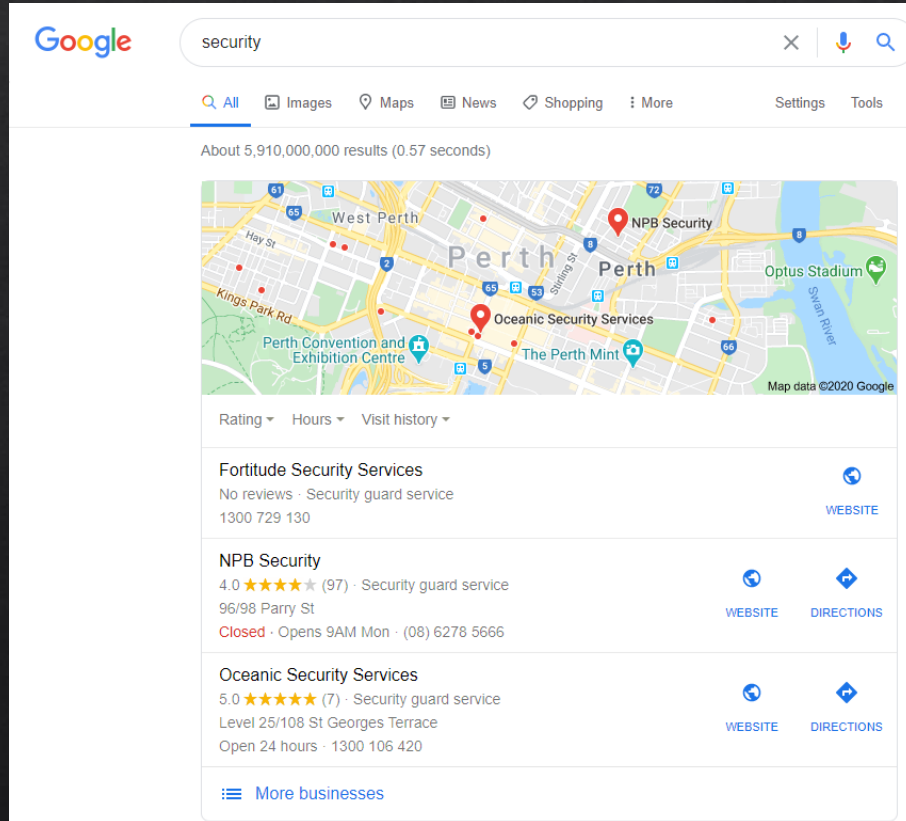


Security – what is it?



“Security is protection from, or resilience against, potential harm (or other unwanted coercion). Beneficiaries (technically referents) of security may be persons and social groups, objects and institutions, ecosystems, or any other entity or phenomenon vulnerable to unwanted change.” - Wikipedia

Information Security – what is it?



“The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide **confidentiality, integrity, and availability**.” - NIST

Security – what is it?

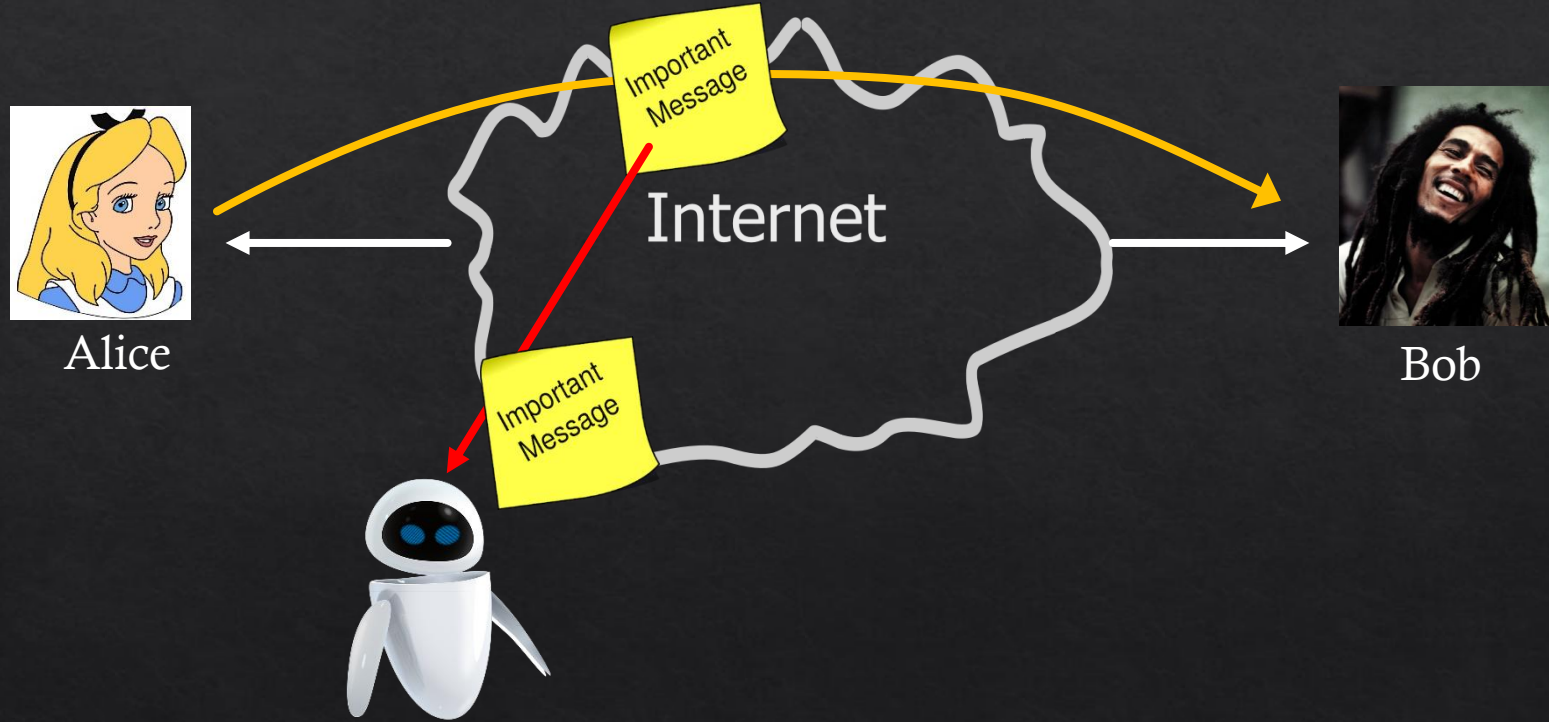
- ◇ The three foundational components in information security
 - ◇ Confidentiality – information is only available to those authorized; e.g., privacy
 - ◇ Integrity – information cannot be modified or damaged by others
 - ◇ Availability – information is always (or to some degree of always) accessible

The CIA Triad

Not this one!



Confidentiality



Confidentiality: the information is only accessible by authorised entities.

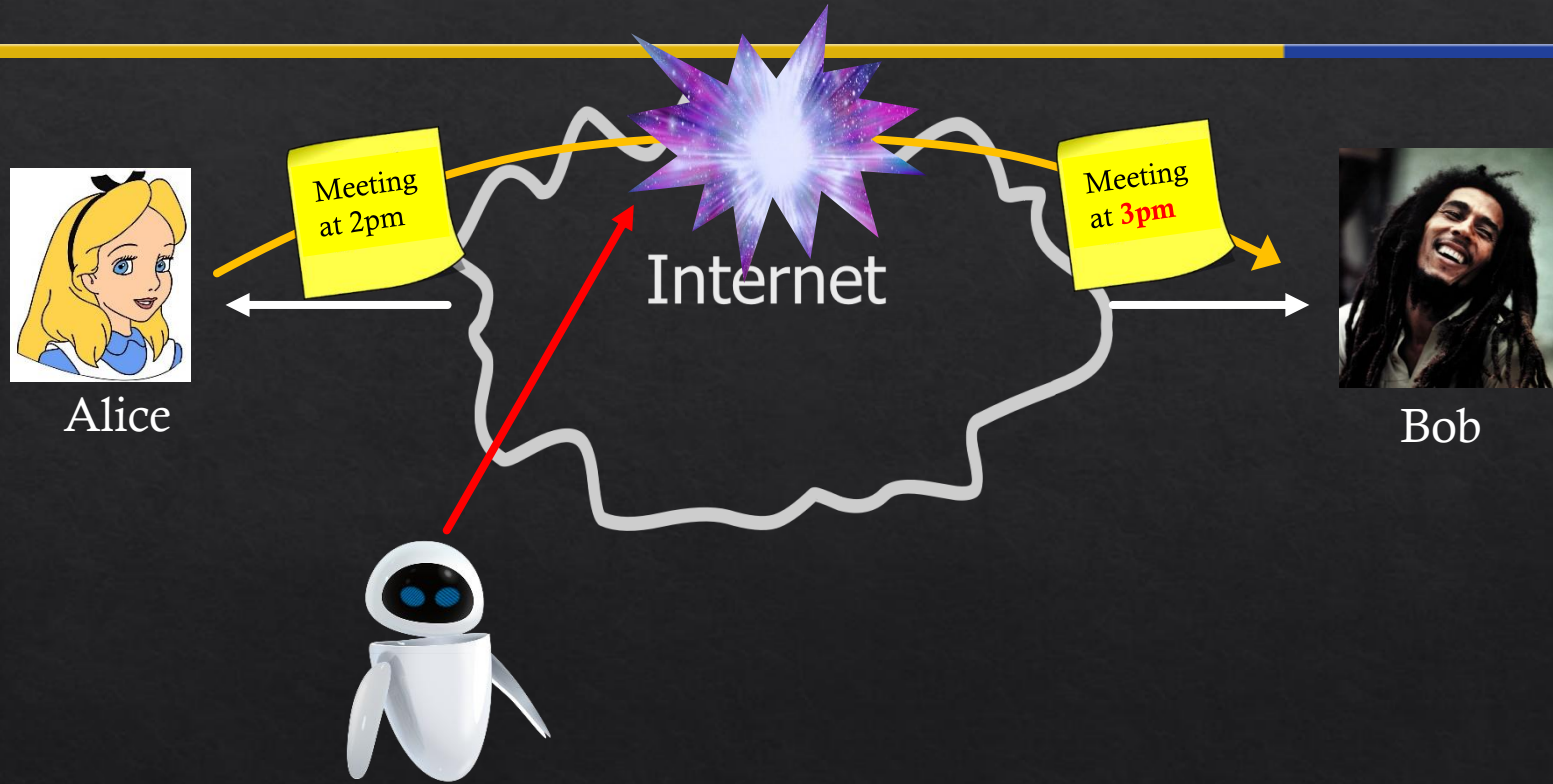
How to achieve...

◆ Confidentiality?

- ◆ Access control
- ◆ Encryption
- ◆ Secure data disposal
- ◆ steganography
- ◆ etc



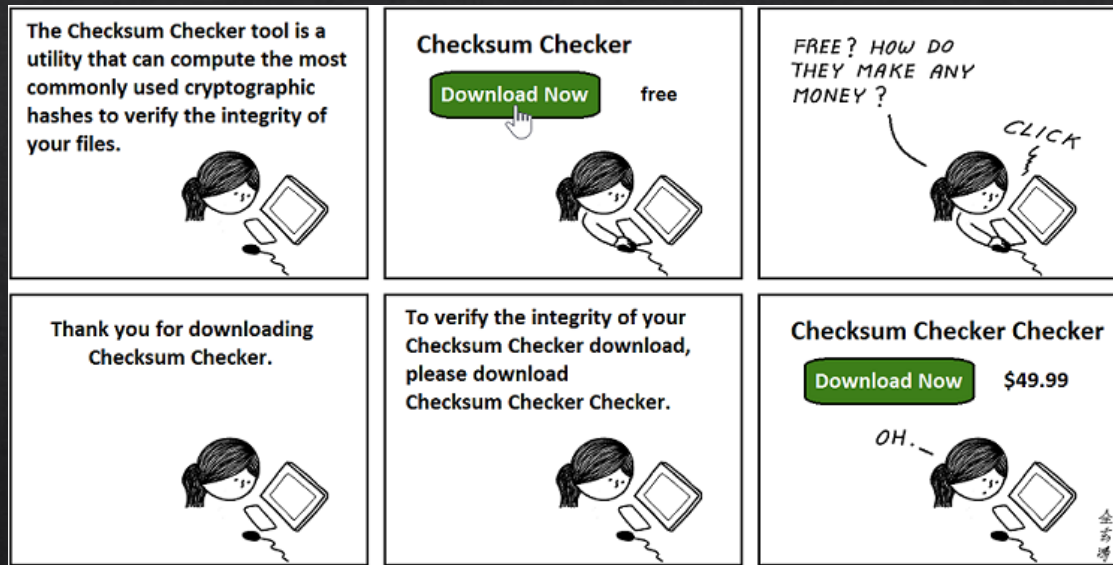
Integrity



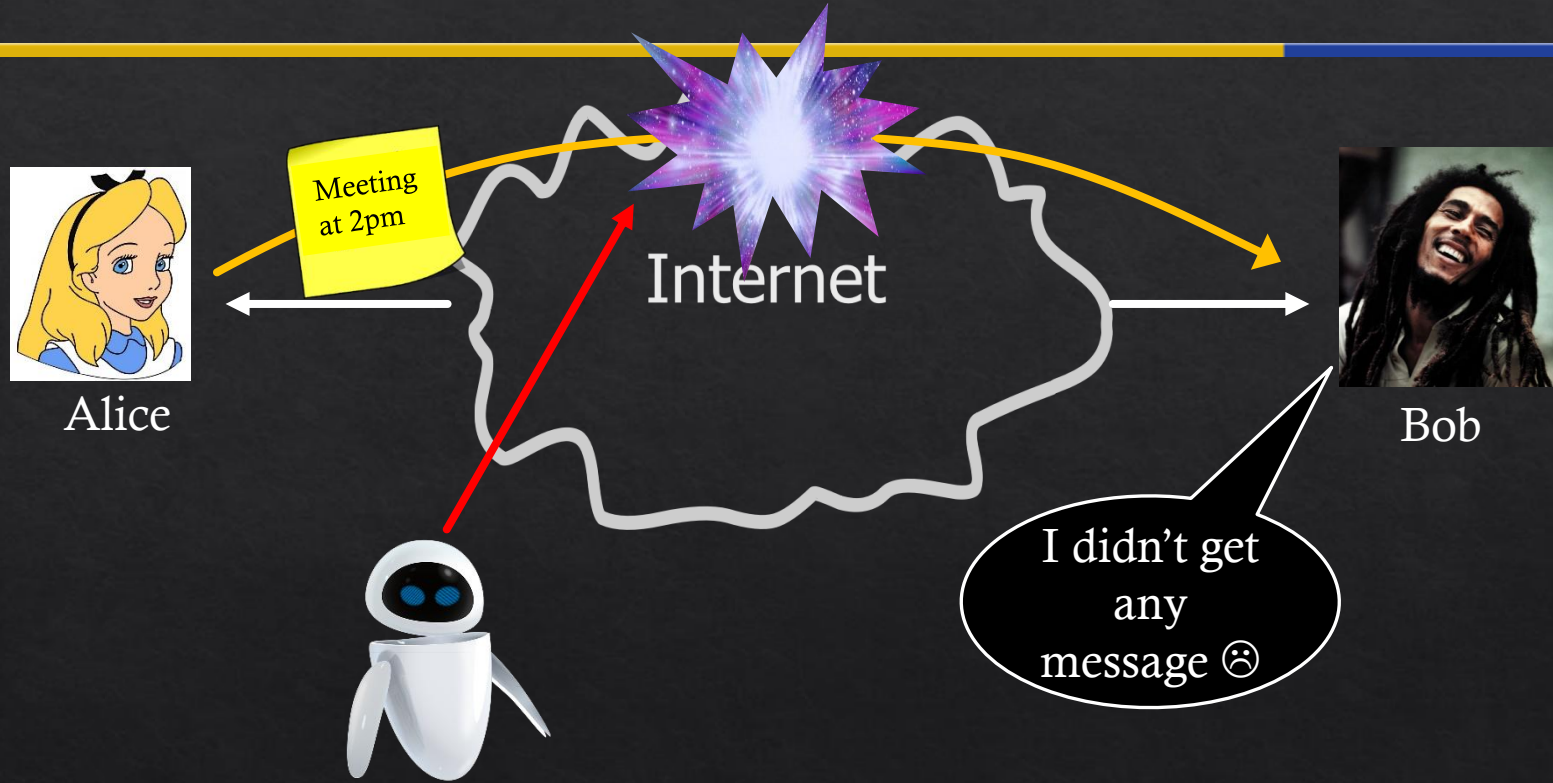
Integrity: the information can only be changed by authorised entities.

How to achieve...

- ◇ Integrity?
 - ◇ Access control
 - ◇ Checksums
 - ◇ Data management
 - ◇ Digital signature
 - ◇ etc



Availability



Availability: the information must be accessible when needed.

How to achieve...

- ◇ Availability?
 - ◇ Redundancy
 - ◇ Backup & recovery
 - ◇ DoS detection/mitigation
 - ◇ Vulnerability patch
 - ◇ etc



Examples

- ◇ In University (in class exercise)
- ◇ In Business
- ◇ In Government

In University

Confidentiality

- Theme passwords are not disclosed to others
- Personal details are not accessed by unauthorised persons

Integrity

- Student details are not modified improperly
- Newsletters are delivered without unauthorised changes

Availability

- The LMS is accessible 24/7
- Onesearch is functional 24/7

In Business

Confidentiality

- Project data is undisclosed to the public
- Customer details are encrypted and stored securely

Integrity

- An employee cannot modify his/her own salary
- Annual summary data is not improperly modified

Availability

- Paychecks are received on time as stipulated by law
- Internal network is accessible from the Internet

In Government

Confidentiality

- Passport details are kept safe from public access
- Tax return details are not improperly disclosed to others

Integrity

- Passport details should not be modified by unauthorised persons
- Tax return should be made to the correct bank account

Availability

- Passport details are checked in real time when travelling
- Tax return should be made within 20 working days

Security Objectives summary

◆ Confidentiality

- ◆ To prevent, detect and deter improper disclosure of information

◆ Integrity

- ◆ To prevent, detect and deter improper modification of information

◆ Availability

- ◆ To prevent, detect and deter improper denial of access to services

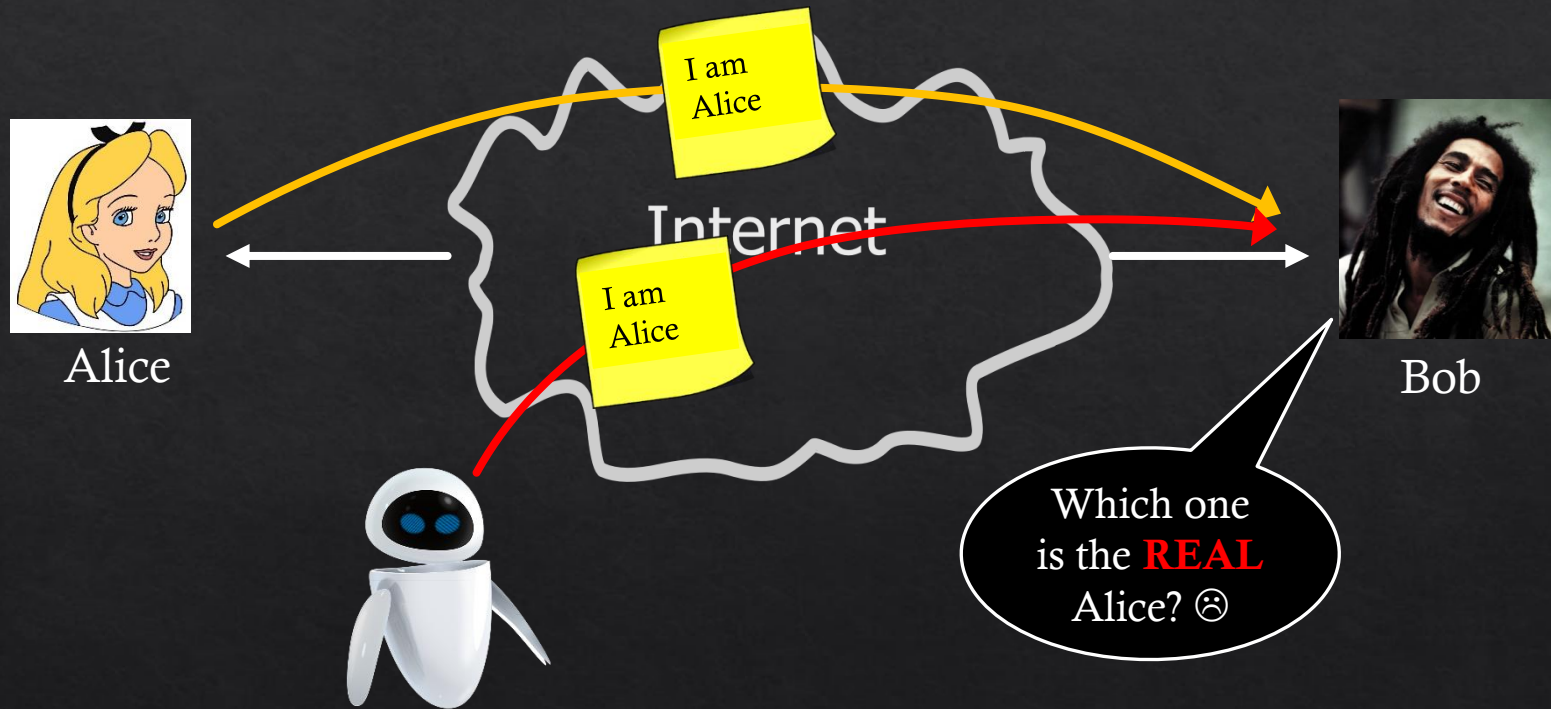
- ◆ These objectives may have different interpretations in **different contexts**.

But wait, there's more! (Five Principles)

- Confidentiality
- Integrity
- Availability
- Authentication
- Non-repudiation



Authentication



Authentication: the entity you are communicating with is who he/she claims.

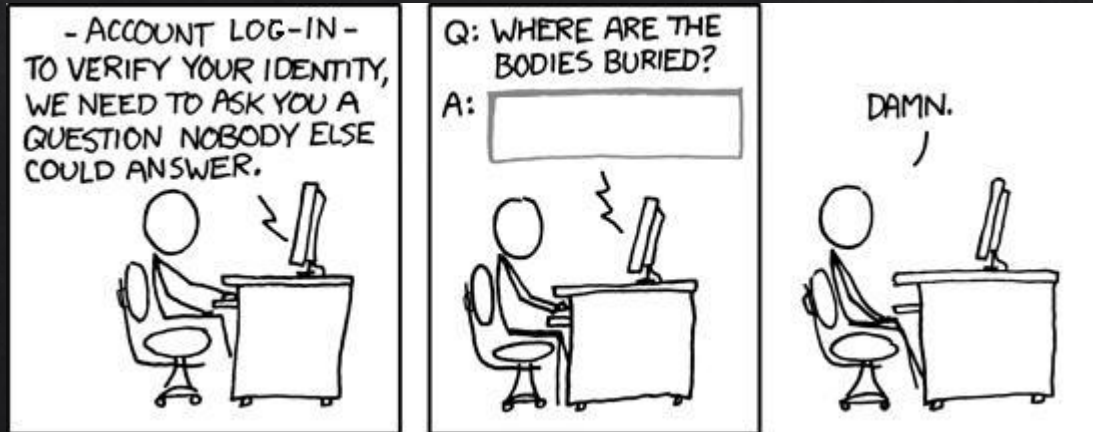
How to achieve...

◇ Authentication?

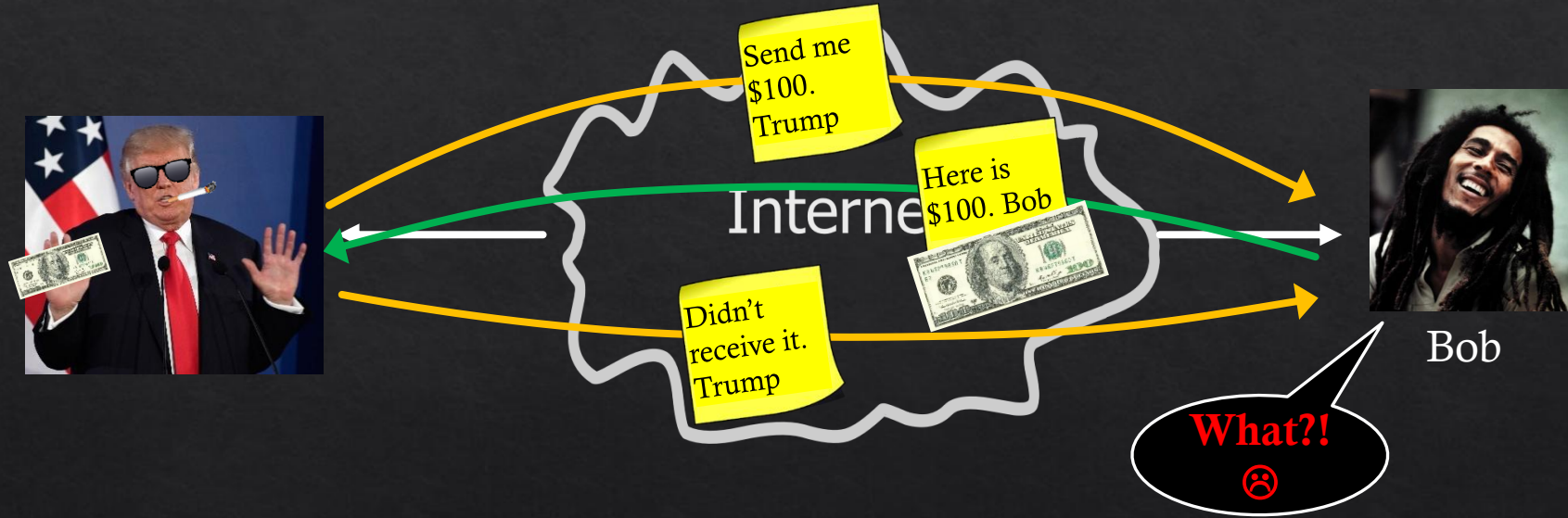
- ◇ Arranged secrecy
- ◇ Something you know/have/are/do
- ◇ etc



Verification
Authentication
Authorization



Non-repudiation



Non-repudiation: entities cannot disclaim their actions.

How to achieve...

- ◇ Non-repudiation?
 - ◇ Audit trail
 - ◇ System restoration
 - ◇ Digital signatures
 - ◇ etc



"Now we will follow this audit trail and catch him"

Questions so far?



Defense overview

- ◇ There are many actions against cyberattacks.
 - ◇ Acceptance
 - ◇ Avoidance (e.g., using paypal not storing customer payment card information)
 - ◇ Transfer
 - ◇ Mitigate
 - ◇ Etc...

Accept → “I might get wet. That’s fine.”

Avoid → “I won’t go outside.”

Transfer → “I hire someone else to walk in the rain.”

Mitigate → “I carry an umbrella or wear raincoat.”



We will focus on the mitigation approaches

Defense overview

◇ Three types in general.

Prevention

Such as: access control (e.g., firewall)

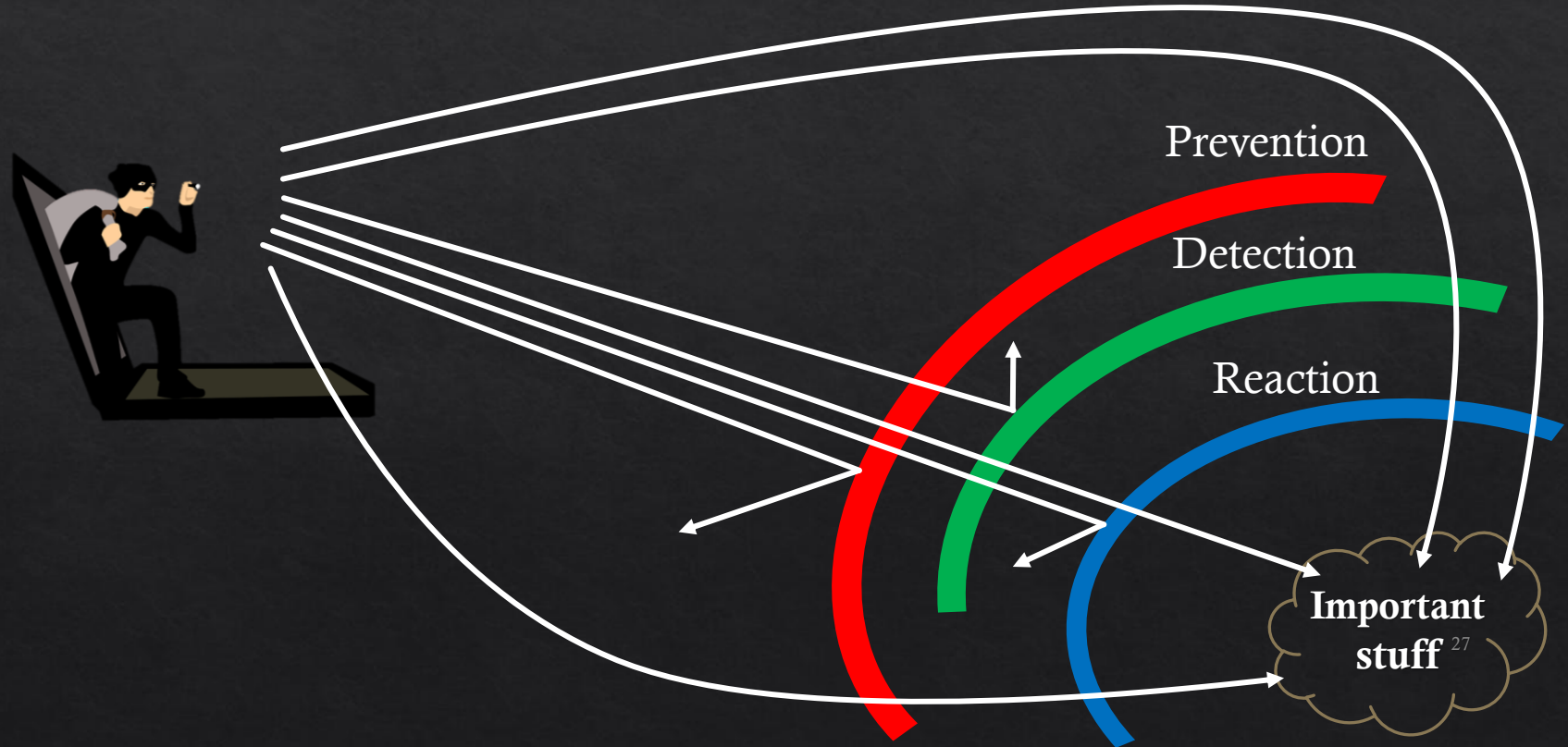
Detection

Such as: auditing and intrusion detection (e.g., IDS, forensics)

Reaction

Such as: intrusion tolerance (e.g., replication, rotation)

Defense overview



Prevention examples

- ◆ Prevention aims to protect your assets from attacks
 - ◆ Using encryptions for secure communication
 - ◆ Authentication of legitimate users in the system
 - ◆ User information is kept confidential



Detection examples

- ◆ To discover the damage to your asset (what, how, when, who, where).
- ◆ Unauthorised access attempts in the log
- ◆ Packet tracing
- ◆ Intrusion detection systems

2019-04-20 16:27:26 PDF pcap
osxdaily.com

No.	Source	Destination	Captured Length	Packet Length	Protocol	Time Received	Time Delta	Information
42	253	253	253	253	RadiusTap	2019-04-20 16:27:33.146	1838683	Ver=0, Pmt=0...
43	253	253	253	253	RadiusTap	2019-04-20 16:27:33.881	1390864	Ver=0, Pmt=0...
44	253	253	253	253	RadiusTap	2019-04-20 16:27:33.881	1843296	Ver=0, Pmt=0...
45	253	253	253	253	RadiusTap	2019-04-20 16:27:33.956	1545662	Ver=0, Pmt=0...
46	253	253	253	253	RadiusTap	2019-04-20 16:27:33.956	2248070	Ver=0, Pmt=0...
47	253	253	253	253	RadiusTap	2019-04-20 16:27:33.960	2365450	Ver=0, Pmt=0...
48	253	253	253	253	RadiusTap	2019-04-20 16:27:33.963	2352715	Ver=0, Pmt=0...
49	710	710	710	710	RadiusTap	2019-04-20 16:27:33.963	2349653	Ver=0, Pmt=0...
50	710	710	710	710	RadiusTap	2019-04-20 16:27:33.965	2351260	Ver=0, Pmt=0...

Details

Values

- Date received: 2019-04-20 16:27:33.959 (-0700)
- Time since first packet: 2.340553 seconds
- Packet length: 710 bytes
- Captured length: 710 bytes
- RadiusTap header
 - Version: 0
 - Padding: 0
 - Length: 25

Hex

0000: 00 00 10 00 0f 00 00 00 76 03 3f 5d 00 00 00 02 24 78 89 89 84 a0 a1 00 c2 84 72 06 79
0001: 66 8f c4 15 a6 3a 2f ae 7a 9b 00 2a c8 f8 b8 da 25 59 2f 39 26 88 f3 84 c8 11 52 f2 6c
0002: 20 05 54 14 81 8c 8c 86 69 68 33 85 87 46 87 08 1a 8c ff 5c 47 20 c3 2f e3 c8 3c 71 75
0003: 68 89 43 1c 84 88 af 3e 1f 8a 39 75 4f 28 f3 0c 19 8e ff 12 00 07 5a 1c 3f 1a f3 74 cf 79
0004: 6f 80 80 81 a3 55 11 87 47 03 8a 80 e1 77 8a 89 1f 1c 8e 58 8a 88 88 5f 23 8e 8e 84
0005: 15b: 45 7c 77 80 85 48 72 48 78 c3 8e 5c 48 a0 8e 87 89 8a e2 c3 11 23 7f 4a 44 91 a6 ac da 85
0006: 02 83 89 75 66 36 a6 38 da 78 03 30 a4 33 52 6c 5a 48 08 c2 f2 13 96 7a 01 8f 29 a1
0007: 23 70 6a 84 02 14 8a 58 71 fa 81 30 f2 56 83 c3 1a 02 8f 02 79 58 c3 20 75 80 88 f6 82
0008: a3 f5 40 c0 88 18 70 7f 30 83 39 06 96 0f 67 5d 51 94 70 fd 1c 71 7f 53 99 88 64 a0 6a c3
0009: af 77 45 14 40 1c 58 51 35 74 28 46 4c 13 18 5d 43 41 99 6a 4c f1 18 26 0e 8c a1 08 2c 97
0010: c2 af 88 18 18 3f 98 c8 ac 89 c3 c2 ff 8f 83 94 54 c9 e8 ee f4 88 98 e8 a5 80 9a aa
0011: 48 c5 c3 c8 78 38 8c 6c 64 f1 80 82 6c 59 49 8f 60 c2 9f 56 af 18 36 57 8f 8f 2a 08 26
0012: 78 81 cf c7 35 88 6f 2a f6 c4 1c 43 a1 c1 6c 9e 6a 58 1a c8 a5 2f fa c7 02 97 18 f2 f6 97

Performance: 0.4 Bps/length: 624266 bytes Linkage: R0380211-RACD Filesize: 100000 bytes Packets: 830 of 830 selected

DEVICE SECURITY



Threat found

Last scanned: Never

SCAN PHONE

SYSTEM PROTECTION

Unauthorised actions have been detected.
Restart your phone to undo these actions.

RESTART

Reaction examples

- ◇ To enhance security and mitigate attacks.
 - ◇ Deploy two-factor authentication
 - ◇ Revoke malicious membership/access
 - ◇ Enforce deterrence



Defense Mechanisms

- ◆ Defense mechanisms includes
 - ◆ Firewall
 - ◆ Vulnerability scanning and patching
 - ◆ IDS and IPS
 - ◆ Security Protocols
 - ◆ IPSec and VPN
 - ◆ Sandboxing
 - ◆ Moving Target Defense
 - ◆ *etc...*

We will cover those in detail later

Risk control/management

- ◆ It is **impossible** to eliminate all risks, making it crucial to identify, prioritize, and mitigate the threats that pose the highest danger to critical assets.
- ◆ Every organisation has to make difficult decisions around **how much time** and **money** to spend protecting their technology and services.

Risk control/management

- ❖ Risk: **unwanted** outcome by a potential **threat**.
- ❖ PDCA (Plan-Do-Check-Act) is an iterative four-step management method used for control and continuous improvement of processes, products, or services.

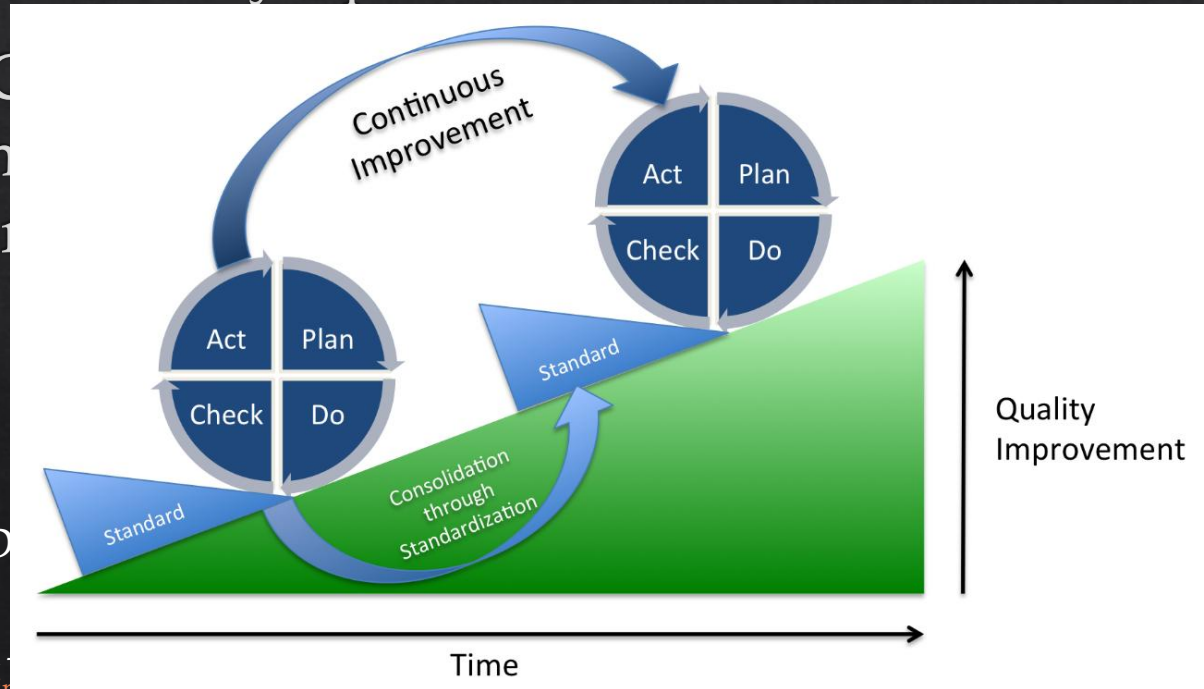
<https://en.wikipedia.org/wiki/PDCA>

ISMS: Information Security Management System

Source: International Organization for Standardization - <https://www.iso.org/standard/27001>
<https://digitaloctopii.com/blog/what-is-isms/how-to-implement-isms-iso-27001/>

Risk control/management

- ❖ Risk: **unwanted** outcome by a potential **threat**.
- ❖ PDCA (Plan-Do-Check-Act) management method for the improvement of processes



<https://en.wikipedia.org/wiki/PDCA>

ISMS: Information Security Management System

Source: International Organization for Standardization

<https://digitaloctopii.com/blog/what-is-isms/how-to-implement-isms-iso-27001/>

Risk control/management

The PDCA is used not only for information security.

- ❖ **Safety & Compliance:** Used in ISO 45001 (Occupational Health & Safety) to manage workplace risks.
- ❖ **Quality Management:** Ensures consistent processes and continuous improvement.

<https://en.wikipedia.org/wiki/PDCA>

ISMS: Information Security Management System

Source: International Organization for Standardization - <https://www.iso.org/standard/27001>
<https://digitaloctopii.com/blog/what-is-isms/how-to-implement-isms-iso-27001/>

Risk control/management

- ◇ Risk: **unwanted** outcome by a potential **threat**.
- ◇ **Information Security**: Falls under ISO/IEC 27001:2022

Risk control/management

- ◇ Risk: **unwa**
- ◇ Falls under

12. Continuous improvement

11. Operate ISMS - Internal audits, measures, monitoring, management reviews



1. Objectives
2. Scope
3. Asset inventory
4. Risk management framework
5. Identify risks and score them
6. Define risk treatment plans
7. Validate controls – Annex A
8. Write documentation

9. Implement plans (technical and procedural)
10. Manage change

ISMS: Information Security Mana

Source: International Organization
<https://digitaloctopii.com/blog/w>

Risk control/management

Step	Description
1. Define objectives	Establish what you want to achieve with the ISMS and secure top management commitment.
2. Define your scope	Determine the boundaries of the ISMS (which information, systems, processes are included).
3. Make an inventory of assets	Identify and document information assets, including hardware, software, people, and processes.
4. Define your risk management framework	Establish a structured methodology for identifying, analyzing, and evaluating risks.
5. Identify the risks and score them	Assess threats and vulnerabilities, then evaluate their likelihood and impact.
6. Develop risk treatment plan(s)	Decide how to treat each risk (mitigate, avoid, transfer, or accept).
7. Verify risk treatment plans against Annex A controls	Map selected treatments to ISO 27001 Annex A controls and justify inclusions/exclusions.

Risk control/management

- | | |
|--|---|
| 8. Write documentation | Develop ISMS policies, procedures, and supporting documentation. |
| 9. Implement technical risk-mitigating solutions | Apply security controls and technical safeguards according to the treatment plan. |
| 10. Manage the change | Conduct training, awareness, and change management to support ISMS adoption. |
| 11. Operate your ISMS | Monitor performance, conduct internal audits, and ensure controls function effectively. |
| 12. Continuous improvement | Review findings, address nonconformities, and enhance the ISMS through ongoing PDCA cycles. |

Risk Management

- ◇ Risk management has a defined standard
 - ◇ ISO/IEC 27001:2022
- ◇ “...*preserves the confidentiality, integrity and availability of information by applying a RISK MANAGEMENT process...*”.
- ◇ 11 clauses (0 to 10): 7 mandatory clauses (Clause 4 to 10) are defined in this ISO. These 7 clauses collectively enforce a management-driven, risk-based, auditable, and continuously improving security system.
- ◇ A comprehensive Annex A for controls (this control list needs to be checked and met)

Risk Management

Clause 4: Context of the organization	Establishes <i>why</i> information security is needed by defining the organization's internal/external environment, identifying stakeholders' security expectations, and setting the formal scope of the ISMS so responsibilities and boundaries are unambiguous.
Clause 5: Leadership	Makes information security a top-management responsibility by requiring leadership commitment, an approved security policy, and clearly assigned roles, preventing security from being treated as a purely technical or IT-only issue.
Clause 6: Planning	Institutionalizes risk-based security by mandating systematic risk assessment, risk treatment decisions, and measurable security objectives, ensuring controls are justified by risk rather than ad-hoc or checklist compliance.
Clause 7: Support	Ensures the ISMS is operationally sustainable by requiring adequate resources, staff competence, security awareness, effective communication, and controlled documentation to support consistent and repeatable security practices.

Risk Management

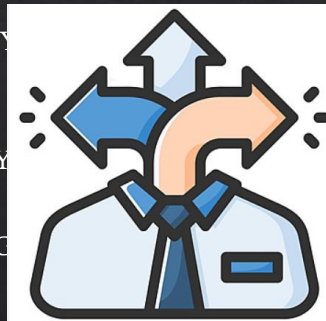
Clause 8: Operation	Requires the organization to actually implement and operate the planned security controls, including managing changes and third-party processes, ensuring security plans are translated into real, day-to-day practices.
Clause 9: Performance evaluation	Forces evidence-based assurance by requiring monitoring, measurement, internal audits, and management reviews to verify whether the ISMS is effective and aligned with business and risk objectives.
Clause 10: Improvement	Embeds continuous improvement by mandating incident handling, corrective actions, and lessons learned, ensuring the ISMS evolves in response to failures, changes, and emerging threats.

Risk Management

Standard	Issuing Body	Scope / Focus	Cybersecurity -Specific?	Certifiable?	Typical Use Case
ISO/IEC 27001	ISO/IEC	Information Security Management System (ISMS) requirements	Yes	Yes	Organizational ISMS certification
ISO/IEC 27005	ISO / IEC	Risk management guidance supporting ISO 27001	Yes	No	Structured cyber risk assessment methodology
ISO 31000	ISO	Enterprise-wide risk management principles	General	No	Corporate risk governance
ISA/IEC 62443	International Society of Automation / IEC	Industrial Control Systems (ICS) and Operation Technology (OT) cybersecurity	Yes (OT focus)	Partial (component/system-level)	Critical infrastructure protection
FIPS 199	NIST	Security impact categorization for federal systems	Yes	Mandatory for US federal	Federal system classification
FIPS 200	NIST	Minimum security requirements for federal systems	Yes	Mandatory for US federal	US government compliance

Risk Management

Standard	Issuing Body	Scope / Focus	Cybersecurity -Specific?	Certifiable?	Typical Use Case
ISO/IEC 27001	ISO/IEC	Information Security Management System (ISMS) requirements	Yes	Yes	Organizational ISMS certification
ISO/IEC 27005	ISO / IEC	Risk management guidance supporting ISO 27001	Yes	Yes	Structured cyber risk assessment methodology
ISO 31000	ISO	Enterprise-wide risk management principles	Core	Yes	Corporate risk governance
ISA/IEC 62443	International Society of Automation / IEC	Industrial Control Systems (ICS) and Operation Technology (OT) cybersecurity	Yes (OT focus)	Partial (component/system-level)	Critical infrastructure protection
FIPS 199	NIST	Security impact categorization for federal systems	Yes	Mandatory for US federal	Federal system classification
FIPS 200	NIST	Minimum security requirements for federal systems	Yes	Mandatory for US federal	US government compliance



Cyber-something

- ◇ Cybersecurity is not only about security mechanisms and methodologies.
- ◇ A broader aspect of the cyberspace safety must be considered.
- ◇ A lot of cyber-something nowadays, let's have a look at a few of interest.

Cyber-something

Cybersecurity

Cyberwarfare

Cyberhacktivism

Cybercrime

Cyberattack

Cybersecurity

“The activity or process, ability or capability, or state whereby information and communications systems and the information contained therein are **protected** from and/or defended against **damage, unauthorized use or modification**, or **exploitation**.” – CNSSI, NIST, DHS and White House

Cyberattack

- ◇ Cyberattack is an act of malicious activities in the cyberspace that causes harm to legitimate entities.
 - ◇ i.e., violating the CIA
- ◇ There are various entities that conduct cyberattacks.
 - ◇ Script kiddies
 - ◇ Black/White Hat Hackers
 - ◇ Hacktivists
 - ◇ Organised criminals
 - ◇ Nation States

Cybercrime

- ◇ Activities in the cyberspace that violates the laws and regulations.
- ◇ Cybercrimes not only affect financially, but also socially, psychologically and physically.
- ◇ There are laws and regulations to punish cybercrimes.
 - ◇ See the cybercrime details from the Australian Government Attorney-General's Department
 - ◇ <https://www.ag.gov.au/CrimeAndCorruption/Cybercrime/Pages/default.aspx>
- ◇ Still a global issue.

<https://www.acorn.gov.au/learn-about-cybercrime>

Cyberhacktivism

- ◇ May have other intentions than cybercriminals
 - ◇ i.e., not just personal gains
 - ◇ Data leak (e.g., through hacking)
 - ◇ Website defacement
 - ◇ DoS/DDoS
- ◇ Hacktivists pursue:
 - ◇ Political statements
 - ◇ Public embarrassment
 - ◇ Awareness or protest
 - ◇ Activism or support of a cause

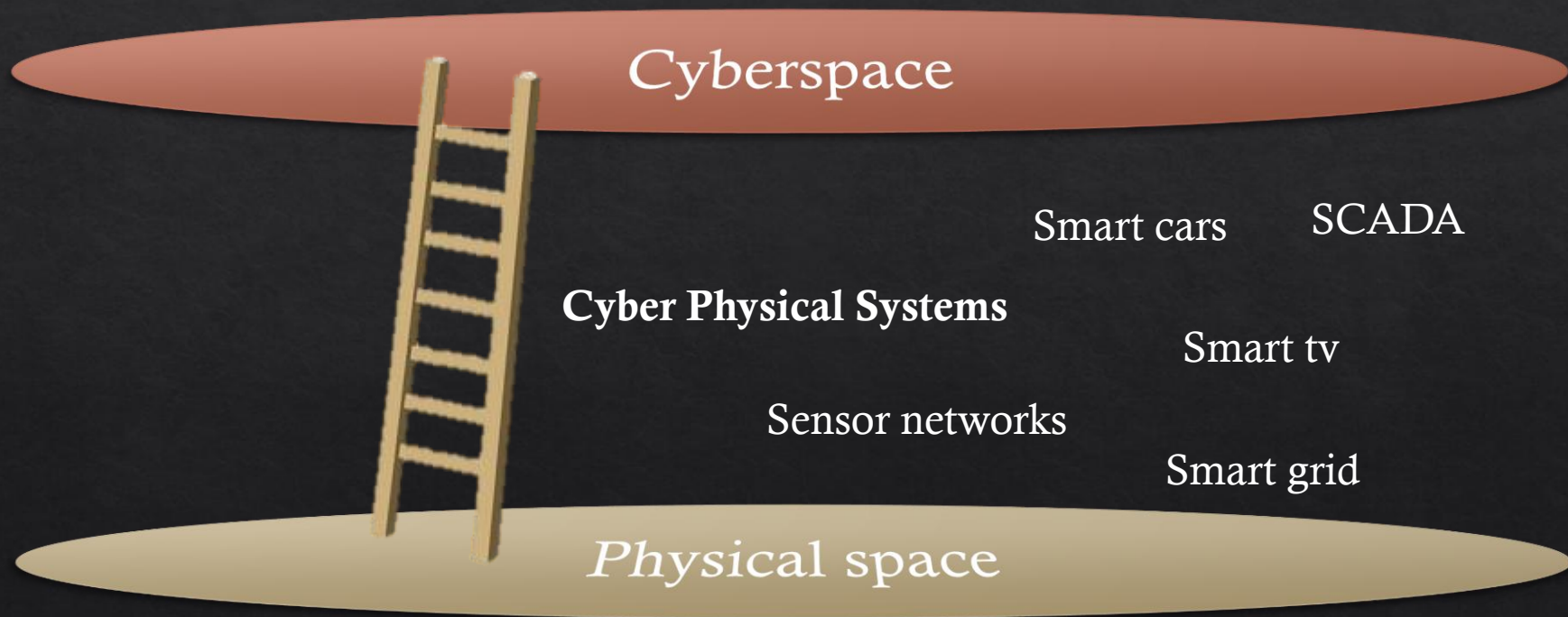


A picture of Mr Bean put on a Spanish government website by a hacker to replace an image of the prime minister, José Luis Rodríguez Zapatero (2010)

Cyberwarfare

- ◇ It's a war!
 - ◇ Involving both attack and defense, but in the cyberspace
- ◇ Involves orchestrated cyberattacks, hacktivism, as well as spies, espionage, sabotage, propaganda and deterrence.
- ◇ Targets
 - ◇ Power grids
 - ◇ Elections
 - ◇ Military systems
 - ◇ Critical infrastructure

Importance of cyber



Additional Items

- ◇ A glossary of cybersecurity terms
 - ◇ <https://niccs.us-cert.gov/glossary>
- ◇ List of ISO standards (like, all of them)
 - ◇ <http://standards.iso.org/ittf/PubliclyAvailableStandards/index.html>

Pre-reading materials

- ◇ Crypto stuff pre-reading/watching:
 - ◇ Youtube video (9 mins): <https://youtu.be/fNC3jCCGJ0o>
 - ◇ Cryptography Introduction (6 mins): <https://www.geeksforgeeks.org/cryptography-introduction/>
 - ◇ Basic Principles (4 mins): <https://www.thegeekstuff.com/2012/07/cryptography-basics>
 - ◇ Intro to public key cryptography (3 mins):
 - ◇ <https://www.globalsign.com/en/ssl-information-center/what-is-public-key-cryptography/>
 - ◇ Intro to RSA (15 mins):
 - ◇ <http://www.dragonwins.com/domains/getteched/crypto/rsa.htm>
 - ◇ Don't have to read thoroughly, just get the idea...